

MMA Fighter Election

Rapport de mise en œuvre — Phase 4

SAÉ S4 — BUT Informatique
Université de Lorraine

COURTOIS Arthur · SCHMITT Lilian

Rendu code : 5 juin 2026 | Soutenance : 12 juin 2026
GitLab : gitlab.univ-lorraine.fr/e49409u/sae_s4_schmitt_courtois

1. Contexte et objectif

L'application héritée MMA Fighter Election est une plateforme de vote permettant d'élire le meilleur combattant MMA de l'année. Elle distingue trois types d'utilisateurs : public, journalistes et coachs, avec un système de pondération des votes (20 % / 40 % / 40 %).

À la suite des audits de sécurité, de performance et de robustesse réalisés en Phase 3, nous avons conduit une campagne de corrections complète sur le code source original. Ce rapport documente l'ensemble des modifications apportées, leur état de réalisation et les gains mesurés.

2. État de réalisation global

Domaine	Points identifiés	Points corrigés	Taux
Sécurité	12	12	100 %
Performance	8	8	100 %
Infrastructure / Docker	4	4	100 %
Robustesse	5	5	100 %
Total	29	29	100 %

3. Modifications de sécurité

3.1 En-têtes HTTP sécurisés

Fichier : `includes/security.php`

L'application ne définissait aucun en-tête HTTP de sécurité, exposant les utilisateurs aux attaques XSS, clickjacking et injection de contenu.

Modifications apportées :

- Content-Security-Policy (CSP) : restriction des sources autorisées pour les scripts, les styles, les polices et les iframes. Toute ressource externe non listée est bloquée.
- X-Frame-Options: DENY — empêche l'intégration dans une iframe (clickjacking).
- X-Content-Type-Options: nosniff — interdit le MIME sniffing navigateur.
- Referrer-Policy: strict-origin-when-cross-origin — limite les données envoyées dans Referer.
- Permissions-Policy — désactive caméra, microphone et géolocalisation.

Gain : note sécurité Mozilla Observatory passée de F à A.

3.2 Protection CSRF

Fichier : `includes/security.php`

Aucun mécanisme anti-CSRF n'était présent. Un attaquant pouvait soumettre des actions (vote, suppression de compte) à la place d'un utilisateur authentifié.

Modifications apportées :

- `csrf_token()` : génère un jeton aléatoire de 32 octets (`random_bytes`) stocké en session.
- `csrf_field()` : génère le champ HTML `<input type="hidden">` à inclure dans chaque formulaire.
- `csrf_verify()` : vérifie la correspondance et déclenche une erreur HTTP 403 en cas d'échec.
- Intégration dans tous les formulaires d'action : connexion, inscription, vote, suppression, contact.

3.3 Rate limiting — limitation des tentatives de connexion

Fichiers : `includes/security.php`, `pages/login.php`

L'absence de limitation permettait les attaques par force brute sur le formulaire de connexion.

Modifications apportées :

- Fonction `rateLimit(key, max, window)` basée sur la session PHP.
- Limite : 5 tentatives échouées par fenêtre de 5 minutes, puis blocage temporaire avec compte à rebours.

3.4 CAPTCHA Google reCAPTCHA v2

Fichiers : `includes/config.php`, `includes/security.php`, `pages/login.php`, `pages/register.php`

Les formulaires d'authentification n'avaient aucune protection contre les soumissions automatisées.

Modifications apportées :

- Constantes RECAPTCHA_SITE_KEY et RECAPTCHA_SECRET_KEY dans config.php (surchargeables par variables d'environnement Docker).
- Fonction recaptcha_verify(token) : appel à l'API Google Siteverify, retourne false si la clé est absente (safe default).
- Widget reCAPTCHA v2 inséré dans les formulaires de connexion et d'inscription, vérifié côté serveur avant tout traitement.
- CSP étendue : ajout de google.com et gstatic.com dans script-src, style-src, img-src et frame-src.

3.5 Pages d'erreur et gestion des exceptions

Fichiers : errors/403.php, errors/500.php, errors/503.php, includes/error_handler.php

Les erreurs PHP affichaient la stack trace complète en production, révélant des informations sensibles.

Modifications apportées :

- Gestionnaire centralisé (set_error_handler, set_exception_handler) : journalisation dans logs/, message générique en production.
- display_errors = 0 et log_errors = 1 imposés dans security.php.
- Pages HTTP 403, 500 et 503 intégrées au design (Tailwind CSS).
- ServerTokens Prod et ServerSignature Off dans le Dockerfile Apache.

3.6 Masquage du listing de répertoires

Fichier : docker/apache.conf

La directive Options -Indexes a été ajoutée dans la configuration Apache pour interdire l'affichage du contenu des répertoires non couverts par un index.php.

3.7 Sécurisation des sessions PHP

Fichier : includes/config.php

Les cookies de session étaient créés sans attributs de sécurité.

Modifications apportées :

- httponly: true — cookie inaccessible en JavaScript (protection XSS).
- samesite: 'Strict' — protection CSRF supplémentaire.
- lifetime: 0 — session fermée à la fermeture du navigateur.

4. Modifications de performance

4.1 Cache applicatif

Fichiers : includes/cache.php, pages/candidats.php, pages/resultats.php, pages/posts.php

Chaque requête HTTP déclenchait systématiquement des requêtes SQL même pour des données peu volatiles.

Modifications apportées :

- Système de cache fichier (/cache/) : fonctions cache_get(key) et cache_set(key, value, ttl).

- TTL 5 minutes pour candidats et scrutins terminés, 1 minute pour le scrutin en cours.

Gain estimé : réduction du nombre de requêtes SQL par page de 4–6 à 0 pour les pages servies depuis le cache.

4.2 Pagination côté serveur

Fichiers : `pages/candidats.php`, `pages/posts.php`

La totalité des enregistrements (candidats, posts) était chargée sans limitation.

Modifications apportées :

- `candidats.php` : 12 candidats par page avec navigation numérotée (LIMIT/OFFSET PDO).
- `posts.php` : 10 posts par page avec liens Précédent / Suivant.
- Paramètres LIMIT et OFFSET passés via `bindValue(PDO::PARAM_INT)` pour prévenir l'injection.

4.3 Élimination des requêtes N+1

Fichiers : `pages/candidats.php`, `pages/resultats.php`

Des boucles PHP effectuaient une requête SQL par candidat pour récupérer les données associées. Remplacement par des requêtes JOIN chargeant toutes les données en une seule passe.

4.4 Index SQL

Fichier : `database/indexes.sql`

Les colonnes filtrées dans les clauses WHERE fréquentes n'étaient pas indexées.

Index ajoutés :

- `candidat(compte_verifie, compte_actif)`
- `vote(ID_scrutin)`
- `electeur(email)`
- `scrutin(phase, date_ouverture, date_fermeture)`

Gain estimé : temps de réponse des requêtes de vote réduit de ~70 % sur les tables volumineuses.

4.5 Minification des assets et cache navigateur

Fichiers : `assets/css/style.min.css`, `assets/js/*.min.js`, `.htaccess`

Modifications apportées :

- Versions minifiées pour `style.css`, `cookies.js` et `countdown.js` (réduction ~30 %).
- `.htaccess` Apache : `mod_expires` avec durée 1 an pour CSS, JS et images.

4.6 Correction du Cumulative Layout Shift (CLS)

Fichiers : `pages/candidats.php`, `pages/resultats.php`, `pages/profil.php`

Les images étaient insérées sans attributs `width` et `height`, provoquant un décalage visuel pendant le chargement (CLS mesuré à 0,228 — seuil "mauvais" Lighthouse).

Modifications apportées :

- Attributs `width` et `height` explicites sur toutes les balises `<img>` dynamiques.

- Attribut `loading="lazy"` sur les images hors-écran (carousel candidats).

Gain : CLS réduit de 0,228 → 0 (score Lighthouse passé de "mauvais" à "bon").

5. Infrastructure et environnement

5.1 Dockerisation

Fichiers : `Dockerfile`, `docker-compose.yml`, `docker/apache.conf`

L'application nécessitait une installation XAMPP locale avec configuration manuelle.

Modifications apportées :

- `Dockerfile` : image `php:8.0-apache`, extensions `PDO/MySQL`, `ServerTokens Prod`, `ServerSignature Off`.
- `docker-compose.yml` : services `app` (PHP/Apache, port 8090) et `db` (MariaDB 12.1) avec volumes pour `logs/`, `cache/`, `uploads/`.
- `docker/apache.conf` : `DocumentRoot` à la racine, Options `-Indexes`, `AllowOverride All`.

Commande de lancement : `docker compose up --build -d`

5.2 Génération sécurisée des codes d'accès

Fichier : `includes/functions_codes.php`

Les codes de vérification professionnels étaient générés avec `str_shuffle()`, non cryptographiquement sûr.

- Remplacement par `bin2hex(random_bytes(8))` — 16 caractères hexadécimaux aléatoires via le CSPRNG du système.

6. Export de la base de données

Le fichier `database/mma_election.sql` (40,9 Ko) contient un dump complet de la base `mma_platform` exporté le 8 juin 2026 depuis le conteneur Docker `mma_db` :

```
docker exec mma_db mariadb-dump -u root -p mma_platform >
database/mma_election.sql
```

Il inclut la structure de toutes les tables ainsi que les données de test (scrutins, candidats, électeurs, votes).

Ce fichier est exclu du dépôt GitLab par `.gitignore` (données sensibles) et doit être livré séparément.

7. Workflow GitLab

Branche	Rôle
main	Code original audité (2 commits initiaux)
develop	10 commits de corrections — prêt à fusionner

Merge Request #2 : `develop` → `main` disponible sur GitLab.

Détail des 10 commits sur develop

#	Hash	Message de commit
1	8694e69	feat(infra): dockerisation de l'application PHP/MariaDB
2	a1fdb04	feat(security): en-têtes HTTP sécurisés, CSRF et rate limiting
3	222c722	feat(security): CAPTCHA reCAPTCHA v2 sur login et inscription
4	f849323	feat(security): pages d'erreur personnalisées et gestionnaire centralisé
5	c499643	feat(perf): cache applicatif, pagination et élimination des requêtes N+1
6	c738c30	feat(perf): cache navigateur, minification des assets et correction du CLS
7	9a6a35a	feat(db): index SQL et génération sécurisée des codes d'accès
8	7b8227e	chore: ajout du .gitignore et suite de tests automatisés
9	d897939	feat(security): validation CSRF et requêtes préparées sur les pages d'action
10	a78d0ec	fix: corrections interface admin, couche PDO et en-tête navigation

8. Récapitulatif des gains mesurés

Indicateur	Avant	Après	Gain
Score Mozilla Observatory	F	A	+5 niveaux
CLS (Lighthouse)	0,228	0,000	-100 %
FCP (First Contentful Paint)	0,7 s	0,7 s	Stable
LCP (Largest Contentful Paint)	1,8 s	~1,2 s	-33 % estimé
Requêtes SQL / page (candidats)	4-6	0 (cache)	-100 %
Listing répertoires Apache	Exposé	Désactivé	✓
Stack trace en production	Visible	Masquée	✓
Protection CSRF	Absente	Complète	✓
Rate limiting connexion	Absent	5 / 5 min	✓
CAPTCHA anti-bot	Absent	reCAPTCHA v2	✓
En-têtes sécurité HTTP	0	5 en-têtes	✓

Document rédigé dans le cadre de la SAÉ S4 — BUT Informatique, Université de Lorraine.